CYBERSECURITY INTERNSHIP PRACTICAL LAB REPORT

Day 06: Spear Phishing Email Craft, MIME Forensics & Email Authentication Defense

Engineering Security-Awareness Training Drafts, Header Spoofing Mechanics, and SPF/DKIM/DMARC Blueprints

INTERNSHIP TRACK: Social Engineering Attack Simulations	**DATE OF EXECUTION:** October 26, 2026
INTERN / RESEARCHER: Md Peer Siddiqui	**TARGET REPOSITORY:** PEER-S-Spear-Phish-Crafter
HOST ORGANIZATION: Sqrock IT Solution	**GITHUB:** github.com/MdPeerSiddiqui
PROGRAM: Phase 1 Alpha 2 Practical Cybersecurity	**EXECUTION ENVIRONMENT:** Kali Linux 2024.x & Win11

1. Executive Summary & Strategic Context

Unlike mass untargeted phishing, **Spear Phishing** represents a precision-guided social engineering methodology where threat actors weaponize Open-Source Intelligence (OSINT) gathered on specific high-value employees. By embedding verified personal details—such as the victim's name, corporate role, division, physical office location, and direct reporting structure—adversaries create pretexts with unprecedented psychological authority and credibility.

For **Day 06** of the Sqrock IT Solution Cybersecurity Internship, a production-grade Python security suite titled **PEER'S Spear Phish Crafter** was engineered. Operating strictly in an authorized laboratory environment, the tool generates three realistic security-awareness simulation drafts (Corporate IT, HR & Payroll, and Supply Chain Finance), analyzes RFC 5322 MIME header spoofing techniques, and establishes an authoritative **SPF, DKIM, and DMARC defender implementation guide** to immunize enterprise domains against inbound spoofing.

2. Scope of Investigation & Technical Objectives

Technical Objective	Methodology & Focus Area	Verification Deliverable
1. Personalized Awareness Drafts	Dynamic token replacement across 3 distinct enterprise attack vectors.	Exported drafts in spear_phish_templates.json.
2. RFC 5322 Header Forensics	Inspection of From, Reply-To, Return-Path, and X-Mailer headers.	MIME header visualizer embedded in CLI and PDF report.
3. Psychological Trigger Analysis	Categorization of cognitive levers (Urgency, Authority, Greed, Fear).	Detailed breakdown table with red-flag detection rules.
4. SPF Deployment Standard	DNS TXT syntax (RFC 7208) defining authorized sending IP ranges.	Production-ready SPF records for Google/M365 relays.
5. DKIM Asymmetric Cryptography	RSA cryptographic signature validation (RFC 6376) on email bodies.	Selector specification and DNS public key configuration.
6. DMARC Alignment & Enforcement	DMARC policy rollout from p=none to p=quarantine and p=reject.	Full alignment matrix (aspf/adkim) and rua reporting setup.
7. Automated Unit Verification	Automated test suite verifying schema, token parsing, and headers.	6 unit tests passing in < 0.005s with 100% pass rate.

3. Anatomy of Spear Phishing & Token Replacement Mechanics

Traditional spam relies on high-volume, generic templates easily trapped by statistical Bayesian filters. Spear phishing bypasses filters by injecting precise organizational context. The Python template engine developed for Day 06 dynamically binds the target's real profile attributes into structural pretexts:

Placeholder Token	Sample Value Injected	Psychological Purpose & Exploitation Impact
{name}	Harish Kumar	Establishes personal address; disables generic spam defenses.
{company}	Sqrock IT Solution	Anchors the communication to authentic organizational reality.
{department}	Cloud Infrastructure & Security	Demonstrates insider knowledge; increases target compliance.
{location}	Bangalore, India	Permits regionalized pretexting and localized operational timing.
{deadline_hours}	24 hours	Imposes cognitive load through artificial time constraints.
{domain_spoofed}	sqrock-portal.com	Deceptive lookalike domain imitating genuine corporate intranet.

4. The 3 Security-Awareness Simulation Vectors: Technical Matrix

To provide holistic defensive coverage across enterprise threat models, three distinct attack vectors were modeled into the engine:

Draft ID & Title	Targeted Division	Spoofed Sender & Reply-To	Core Threat Pretext
[DRAFT-01] Corporate IT: SSO Certificate Renewal	Enterprise IT / IAM	**From:** it-support@sqrock-portal.com **Reply-To:** admin-verification@external-gateway-sync.net	Mandatory Active Directory synchronization; threats 24-hr lockout from VPN, Slack, and Git.
[DRAFT-02] People Operations: Q4 Compensation Review	HR & Payroll	**From:** payroll-review@sqrock-portal.com **Reply-To:** hr-dispatch@talent-benefits-secure.io	Direct deposit routing re-verification; imposes Friday cutoff with confidentiality gag rule.
[DRAFT-03] Finance: Overdue Supplier Wire Settlement	Procurement / Accounts	**From:** billing-accounts@sqrock-portal.com **Reply-To:** vendor-reconciliation@wire-hold-finance.biz	Alleges $18,450.00 overdue cloud services invoice threatening legal escalation and SLA cut.

5. Detailed Security-Awareness Training Drafts

The following formatted drafts illustrate the exact message content presented to employees during controlled internal phishing simulations, accompanied by forensic red flags designed to train vigilance:

[DRAFT-01] Corporate IT Helpdesk Pretext:
From: "Sqrock Global IT Support Desk" <it-support@sqrock-portal.com>
To: "Harish Kumar" <harish.k@sqrock.com>
Subject: ACTION REQUIRED: Security Certificate Expiration for Harish Kumar (Sqrock IT Solution)

Dear Harish Kumar,
Our centralized Active Directory and Okta Single Sign-On (SSO) gateway migration has flagged your endpoint profile as pending mandatory certificate synchronization. Due to corporate compliance policy, failure to bind your hardware multi-factor authenticator within 24 hours will result in automated suspension of your Sqrock IT Solution VPN, Slack, and internal Git repository access.

■ **[MANDATORY ACTION]:** https://login.sqrock-portal.com/sso/auth/verify-token?id=99281-sqr

Regards, Central IT Security Operations — Extension #4401

[DRAFT-02] HR Compensation & Direct Deposit Pretext:
From: "People Operations & Payroll Management" <payroll-review@sqrock-portal.com>
To: "Harish Kumar" <harish.k@sqrock.com>
Subject: CONFIDENTIAL: Updated Q4 Compensation Review & Direct Deposit Routing for Harish Kumar

Hi Harish Kumar,
As part of Sqrock IT Solution's Q4 compensation harmonization across the Cloud Infrastructure & Security division, your updated executive compensation structure and revised tax bracket deductions have been finalized. To guarantee that your upcoming monthly salary disbursement is not placed on administrative hold, you must review and confirm your bank routing details before the payroll cutoff this Friday at 5:00 PM IST.

■ **[CONFIDENTIAL ACCESS]:** https://payroll.sqrock-portal.com/confidential/compensation-statement?emp=HK-9921

Warm regards, People Operations & Benefits Desk

6. Critical Red Flag Forensic Checklist for Employees

- **Domain Dissimilarity:** Legitimate communications originate from @sqrock.com, whereas the email uses lookalike @sqrock-portal.com.
- **Reply-To Redirection:** Hitting 'Reply' routes data to external untrusted domains (external-gateway-sync.net).
- **Artificial Coercive Deadlines:** High-pressure ultimatums (24 hours or Friday cutoff) designed to prevent peer verification.
- **Credential Harvesting Links:** Simulated hyperlinks point to external unverified web applications rather than bookmarked corporate portals.

7. RFC 5322 MIME Email Header Anatomy & Spoofing Mechanics

Email headers contain the definitive telemetry utilized by Mail Transfer Agents (MTAs) and Secure Email Gateways (SEGs). Attackers exploit the historical lack of authentication in the Simple Mail Transfer Protocol (SMTP RFC 821/5321) by injecting forged identity fields into RFC 5322 header blocks:

```
Delivered-To: harish.k@sqrock.com
Received: by mail-gateway.sqrock.internal with SMTP id relay994821;
Mon, 26 Oct 2026 16:15:00 +0000
Authentication-Results: mx.sqrock.internal;
dkim=fail (bad signature / unsigned);
spf=fail (sender IP 198.51.100.44 not in authorized SPF record of sqrock.com);
dmarc=fail (p=REJECT dis=NONE) header.from=sqrock-portal.com
Received-SPF: fail (domain does not designate 198.51.100.44 as permitted sender)
Return-Path:
Message-ID:
Date: Mon, 26 Oct 2026 16:15:00 +0000
From: "Sqrock Global IT Support Desk"
To: "Harish Kumar"
Reply-To:
Subject: ACTION REQUIRED: Security Certificate Expiration for Harish Kumar
MIME-Version: 1.0
Content-Type: text/plain; charset=UTF-8
X-Mailer: Microsoft Outlook 16.0 (Enterprise Client Build 14326.20454)
X-Priority: 1 (Highest)
Importance: High
```

8. Header Dissection & Fraud Indicators

• **Authentication-Results (DMARC/SPF Fail):** The receiving gateway confirms that the originating IP (198.51.100.44) is not permitted under the authorized SPF policy, and no valid cryptographic DKIM signature was presented.
• **Display-Name vs RFC 5322 'From':** The header sets display name to *'Sqrock Global IT Support Desk'* to trick client UIs into hiding the suspicious domain (sqrock-portal.com).
• **Routing Diversion via Reply-To:** When a victim clicks 'Reply' to inquire about the certificate, the client routes the response to the attacker-controlled mailbox: admin-verification@external-gateway-sync.net.
• **Return-Path Divergence:** Non-delivery bounce notices are directed to relay-mailer44.org, proving that the actual SMTP envelope sender differs completely from the displayed organization.

9. Email Defender Blueprint: SPF & DKIM Architecture

To neutralize spoofing, enterprise defenders must deploy a unified email authentication triad consisting of SPF, DKIM, and DMARC. Together, these protocols provide deterministic cryptographic verification of sender identity.

A. Sender Policy Framework (SPF — RFC 7208)

SPF allows domain administrators to publish an authorized list of server IP addresses and third-party mail relays permitted to dispatch emails using their domain in the SMTP HELO and MAIL FROM (envelope) commands.

DNS Record Type: TXT
Host / Subdomain: @ (root domain: sqrock.com)
Production Value: v=spf1 include:_spf.google.com include:sendgrid.net ip4:198.51.100.1 ~all

Syntax Explanation:
• v=spf1: Identifies the TXT record as an SPF version 1 declaration.
• include:_spf.google.com: Authorizes Google Workspace mail relays.
• include:sendgrid.net: Authorizes transactional outbound email services.
• ip4:198.51.100.1: Designates dedicated corporate on-premise mail server.
• ~all: SoftFail — mail from unlisted IPs is accepted but flagged as suspicious for DMARC evaluation.
• -all: HardFail — instructs receiving MTAs to reject unlisted senders immediately.

B. DomainKeys Identified Mail (DKIM — RFC 6376)

While SPF validates the transmitting IP, DKIM protects email content integrity using asymmetric public-key cryptography. An outbound MTA generates a cryptographic hash of the message body and headers, signs it with a private key, and embeds the signature in a DKIM-Signature header. Receiving servers fetch the public key via DNS and verify the signature.

DNS Record Type: TXT
Host / Selector: s2026._domainkey.sqrock.com
Public Key Record: v=DKIM1; k=rsa; p=MIGfMA0GCSqGSIb3DQEBAQUAA4GNADCBiQKBgQC3r...IDAQAB

Security Mechanics:
• k=rsa: Cryptographic algorithm (RSA-2048 recommended for modern security).
• p=...: Base64-encoded public key used by recipients to mathematically decrypt and verify the header hash.
• **Tamper Resistance:** If an attacker modifies even a single character in the email body or subject line, the cryptographic hash fails, immediately invalidating the message.

10. DMARC Enforcement, Alignment & Staged Rollout (RFC 7489)

SPF and DKIM alone have a fundamental vulnerability: SPF checks the *envelope sender* (Return-Path), while DKIM can be signed by any valid domain. Neither guarantees that the address the user sees (the **RFC 5322 From:** header) is authentic. **DMARC** solves this through **Identifier Alignment** and enforces explicit handling policies on unaligned mail.

A. DMARC Identifier Alignment Principle

For an email to pass DMARC, the domain in the visible From: header must align with either the domain verified by SPF (SPF Alignment) or the domain verified by DKIM (DKIM Alignment). Under relaxed alignment (aspf=r), organizational base domains match (e.g., mail.sqrock.com aligns with sqrock.com).

B. The 3-Phase Enterprise DMARC Rollout Strategy

Rollout Phase	DMARC DNS TXT Record	Operational Behavior & Protection Level
Phase 1: Monitoring (30–60 Days)	`v=DMARC1; p=none; rua=mailto:dmarc-reports@sqrock.com; pct=100`	**Zero mail disruption.** Receiving servers process mail normally but send daily XML aggregate reports detailing legitimate and spoofed sending sources.
Phase 2: Quarantine (14–30 Days)	`v=DMARC1; p=quarantine; rua=mailto:dmarc-reports@sqrock.com; pct=100; sp=quarantine`	**Partial enforcement.** Spoofed emails that fail SPF/DKIM alignment are quarantined into the recipient's Spam/Junk folder. Phishing links are neutered.
Phase 3: Rejection (Full Production)	`v=DMARC1; p=reject; rua=mailto:dmarc-reports@sqrock.com; ruf=mailto:dmarc-forensics@sqrock.com; pct=100; sp=reject; aspf=r; adkim=r`	**Complete spoofing immunity.** Any email attempting to forge @sqrock.com without valid SPF/DKIM alignment is **instantly dropped** at SMTP connect time.

C. DMARC Aggregate Reporting Analysis (RUA)

By analyzing the incoming XML reports sent to rua=mailto:dmarc-reports@sqrock.com, security operations centers (SOCs) gain real-time worldwide visibility into: (1) Rogue IP addresses attempting to impersonate corporate executives, (2) Unsanctioned Shadow IT marketing relays lacking DKIM keys, and (3) Emerging spoofing campaigns targeting enterprise customers.

11. Automated Unit Testing Verification Suite

To guarantee execution reliability across Python platforms, PEER'S Spear Phish Crafter includes an automated unit test suite (tests/test_spear_crafter.py) verifying scenario schemas, token replacement, MIME syntax, and DMARC records:

Test Case Identifier	Component Under Test	Execution Time	Status
test_scenarios_data_count_and_keys	Validates exactly 3 scenarios with full schema	0.0004s	**PASS (OK)**
test_render_scenario_body_token_replacement	Ensures zero unparsed token braces in output	0.0005s	**PASS (OK)**
test_render_mime_headers	Verifies RFC 5322 MIME headers and dmarc=fail tag	0.0004s	**PASS (OK)**
test_custom_target_profile_rendering	Tests syllabus target profile (Riya Sharma)	0.0004s	**PASS (OK)**
test_export_deliverable_json	Validates spear_phish_templates.json export	0.0005s	**PASS (OK)**
test_dmarc_defense_policy_records	Validates standard SPF/DKIM/DMARC syntax	0.0003s	**PASS (OK)**

12. Ethical Compliance, Authorized Scope & Legal Boundaries

Ethical Scope: All email templates, sender headers, and lookalike domains generated by this suite are intended strictly for **authorized internal awareness training simulations** and defensive engineering education. No outbound emails were transmitted across public networks without explicit administrative authorization. No credential-harvesting backend servers or malicious payload delivery mechanisms were deployed. All operations adhere strictly to the **Information Technology Act 2000 (India)**, the Computer Fraud and Abuse Act (CFAA), and the Sqrock IT Solution Ethical Guidelines.

13. Intern Declaration & Sign-Off

I hereby declare that this practical lab report and its associated Python CLI implementation represent original engineering work conducted under the supervision of Sqrock IT Solution for Day 06 of the Cybersecurity Internship.
Signature: *Md Peer Siddiqui* | **Date:** October 26, 2026